



Overview

BSBXCS402 Promote workplace cyber security awareness and best practices

ICT60220 - Advanced Diploma of Information Technology

Assessment Task 1 - Knowledge Questions

Information for students

Knowledge questions are designed to help you demonstrate the knowledge which you have acquired during the learning phase of this unit. Ensure that you:

- review the advice to students regarding answering knowledge questions in the Student User Guide
- comply with the due date for assessment which your assessor will provide
- adhere with your Milestones International College's submission guidelines
- answer all questions completely and correctly
- submit work which is original and, where necessary, properly referenced
- avoid sharing your answers with other students.

Begin >



Item 1 of 13

Complete the table below by identifying the title of the legislation for each legislation area and then describing the relevance of the legislation to cyber security and impact on businesses.

Legislation	Legislation title	Relevance to cyber security and impact on business
a. Data protection and privacy	Data protection through the Privacy Act 1988	In Australia, organisations are legally mandated to take reasonable protection to protect the personal information they hold from misuse, interference, loss, unauthorised access, modification, or disclosure. Businesses can face fines : 1. up to \$50 million 2. 3 times the value of the benefit 3. 30% of the company's adjusted turnover during the breach period.
b. Notifiable data breaches	Privacy Amendment (Notifiable Data Breaches) Act 2017	Companies are required, through their security teams, to assess and report whether a data breach is likely to cause serious harm to individuals. Furthermore, it is mandatory to immediately disclose any data breaches that have occurred (involving certain data). They must also notify the affected individuals and the OAIC.
c. International legislation	National Cybersecurity Protection Act of 2014 (USA)	Promotes automated, multi-directional sharing of technical threat indicators and defensive measures between public and private sectors via standardised machine-to-machine protocols (such as STIX/TAXII feeds feed into enterprise firewalls/SIEMs). Offers specific liability protections for businesses that voluntarily share cyber threat indicators with the centre, removing antitrust and privacy exposure to foster an environment of open, rapid defence collaboration.

Answer Saved.

< Overview

Next >



1
2
3
4
4
5
6
7
8
9
10
11
12
13

Item 2 of 13

Answer the following questions about the 'bring your own device' (BYOD) policy.

a. Explain the purpose of this type of policy.

The policy allows for the formal acceptance of personal device use for business purposes. The company can monitor and manage certain applications required for business operations, such as apps or access to the internal network.

What I am allowed/not allowed to do with my device

b. List four requirements you would expect to see in a BYOD policy.

Permissions to data and applications

Risks and mitigations

Information collected

Answer Saved.

< Previous

Next >



1
2
3
4
5
6
7
8
9
10
11
12
13

Item 3 of 13

Answer the following questions about acceptable use policies.

a. Explain the purpose of this type of policy.

It helps protect the organisation's digital assets. It prevents misuse, unauthorised access, and potential security breaches. Defining acceptable behaviour reduces the risk of data leaks, malware infections, and other cyber threats.

b. List four requirements you would expect to see in an acceptable use policy.

Restrictions, applications and activity

Scope of monitoring and privacy

Incident Reporting and Support

Consequences of Violation

Answer Saved.

[< Previous](#)

[Next >](#)



Item 4 of 13

Answer the following questions about data governance policies.

a. Explain the purpose of this type of policy.

This is a framework that provides the basics of data governance that agencies can adapt to suit their needs. Defines who has control over data assets, how those assets are managed, and how their integrity, availability, and security are maintained across the enterprise.

b. List **four** requirements you would expect to see in a data governance policy.

Data Classification

Data Ownership and Stewardship Roles

Data Access Control

Data Lifecycle

Answer Saved.

[< Previous](#)

[Next >](#)



1
2
3
4
5
6
7
8
9
10
11
12
13

Item 5 of 13

Answer the following questions about media/data labelling policies.

a. Explain the purpose of this type of policy.

This policy is to ensure that all corporate data is marked with a visible classification tag that denotes its level of sensitivity.

Classification and labelling schema

b. List **four** requirements you would expect to see in a media/data labelling policy.

Storage control for digital and physical assets

De-labelling Procedures

leak mitigation

Answer Saved.

[< Previous](#)

[Next >](#)



Item 6 of 13

Answer the following questions about data classification and management policies.

a. Explain the purpose of this type of policy.

It is the framework used to securely organise and manage information assets.

Information is classified based on its level of sensitivity.

b. List **four** requirements you would expect to see in a data classification and management policy.

A clearly defined classification of tiers (public, internal, confidential, restricted)

Enforcement rules and data handling baseline (technical control, AES, TLS, WAN/LAN/VPN)

A clear assignment of data roles (owner, custodians, users)

Lifecycle Management (retention, sanitisation)

Answer Saved.

[< Previous](#)

[Next >](#)



Item 7 of 13

Answer the following questions about encryption policies.

a. Explain the purpose of this type of policy.

A framework used to establish cryptographic controls to protect the information assets. The purpose is to keep the information safe from malicious attacks, breaches and incidents.

b. What is meant by encryption?

It is the mathematical process of encoding information into an unreadable format using a cryptographic method.

c. List **two** types of common encryption protocols and briefly explain how they are used.

TLS 1.3 - A common standard protocol used to encrypt traffic between an ATM and the bank's transaction servers.

It creates a secure, encrypted tunnel that protects sensitive session data from packet sniffing or man-in-the-middle (MitM) attacks.

IPsec is used to establish VPNs and encrypted tunnels.

It authenticates and encrypts all traffic at the data packet level (Layer 3)

d. List **two** things that need to be considered when determining protocols for encryption.

Computational capacity: Encryption/decryption requires CPU processing power. Algorithms could increase latency.

The chosen protocol must be compatible with the hardware capabilities and aligned with the company's security policies.

Furthermore, its lifecycle must be taken into account.

Acceptable cryptographic standards

Management lifecycle controls

Data-at-Rest and Data-in-Transit Mandates

Alignment with internal and international policies

e. List **four** requirements you would expect to see in an encryption policy.

Answer Saved.

< Previous

Next >



Item 8 of 13

Answer the following questions about policies related to the secure storage, sharing and management of information.

a. Explain the purpose of this type of policy.

The main purpose is to protect the confidentiality, integrity and availability of the information assets.

These sorts of policies establish a set of rules that serve several management functions, such as:

- Secure storage
- Secure sharing
- Data management

b. List **four** requirements you would expect to see in this type of policy.

Data classification

Approved storage location/devices

Level of access/control

Incident response plan



Item 9 of 13

Complete the table below and identify two Australian government sources of information on current threats. As a minimum identify the website reference and a brief description of the information provided.

Australian government sources of information on current threats**Australian Cyber Security Centre (ACSC):**

The Australian Cyber Security Centre is a public-facing service within the Australian government's Australian Signals Directorate branch. The ACSC itself is designed to be the foremost authority on cybersecurity for Australia (business, government, academic) and international partners.

Provides real-time alerts of cyber threats, also provides technical advice and assistance to help Australian entities respond to cybersecurity incidents.

Source: <https://www.cyber.gov.au/about-us/view-all-content/reports-and-statistics/annual-cyber-threat-report-2024-2025>

Australian Signals Directorate (ASD):

The Australian Signals Directorate (ASD) is an Australian Government intelligence agency responsible for foreign signals intelligence and cyber security.

Provides information security advice and services to Australian federal and state Government agencies.

Source: <https://www.asd.gov.au/about/what-we-do>

Answer Saved.

< Previous

Next >



1
2
3
4
4
5
6
7
8
9
10
11
12
13

Item 10 of 13

List three risks that are associated with workplace cyber security. For each risk, explain how it can occur.

Ransomware double extortion: It has become common to be doubly extorted after being infected by ransomware.

Attackers first steal data and then encrypt it locally. Therefore, they demand a ransom for the stolen data to prevent it from being sold or leaked online. A second ransom is demanded to decrypt the data and prevent business operations from being disrupted.

Phishing and Session Hijacking: Through sophisticated social engineering techniques targeting company employees, attackers obtain credentials and MFA codes for corporate websites.

The attack involves using phishing to redirect the victim to fake website URLs, thereby stealing login information. This allows them to hijack the session on corporate websites.

Third-Party Cloud Vulnerabilities: Attackers often target smaller third-party vendors that provide services to the company. This allows them to exploit vulnerabilities in APIs or cloud instances to gain access to the target company's internal infrastructure.

Answer Saved.

[< Previous](#)

[Next >](#)



1
2
3
4
5
6
7
8
9
10
11
12
13

Item 11 of 13

Choose one well-known company and provide one example of how it promotes cyber security strategies and techniques to its staff.

Cyber conversations: teaming up on security:

During the pandemic, ANZ launched an open dialogue with its employees to prevent cyberattacks.

ANZ identified that most attacks were phishing attacks using emails that infected computers with ransomware.

ANZ's strategy involved developing the PACT Framework (pause, activate, call, turn on). This framework consists of:

1. Pause: Take a moment before processing an urgent request or clicking on a link.
2. Activate: Enable multi-factor authentication on all platforms as an additional security measure.
3. Call: Call it out to verify suspicious activity and contact the person sending the request.
4. Turn on: Enable automatic updates on devices.

They also established a dedicated channel for reporting cybersecurity incidents.

Source: [https://www.anz.com.au/newsroom/news/2021/12/online-cyber-threats-security-acsc/#~:text=When%20people%20come%20and%20talk,and%20patching%20\(updating%20software\).](https://www.anz.com.au/newsroom/news/2021/12/online-cyber-threats-security-acsc/#~:text=When%20people%20come%20and%20talk,and%20patching%20(updating%20software).)

Answer Saved.

< Previous

Next >



Item 12 of 13

Explain how cyber-attack simulations can assist in training staff in cyber security awareness. As part of your answer, include two types of simulations that could be implemented.

Cyberattack simulations can help train staff to implement security policies and practices, reducing employee vulnerability to real attacks.

Furthermore, these exercises allow companies to improve their systems and training programs and obtain metrics on the effectiveness of their security measures.

The types of simulations are:

- Red Team (Simulate adversarial attacks): This is a full-scope, stealth simulation where ethical hackers mimic a real-world threat actor. They try to infiltrate the network by any means necessary (social engineering, exploiting unpatched edge devices, physical tailgating) without warning the general IT staff.

- Blue Team (Teams respond to simulated attacks): This simulation focuses entirely on the defensive side. It tests how quickly and effectively the internal security team detects, contains, and mitigates a simulated live threat (such as an active ransomware outbreak or an unauthorized credential sweep) traversing the network.

- Purple Team (Combine red and blue teams): This is a highly collaborative, transparent simulation workshop. Instead of working in secret, the Red Team executes a specific attack technique in real-time right in front of the Blue Team. Both teams immediately inspect the logs together to see if the network infrastructure detected it, allowing them to optimize firewall rules and SIEM alerts on the spot.

- Capture the Flag (Identify and exploit vulnerabilities): While often run as a competitive game, CTF is a gamified tactical simulation. It places participants in a controlled sandbox environment where they must solve specialized security puzzles (such as cracking an encryption protocol, reverse-engineering malware, or exploiting a web vulnerability) to find a hidden piece of text (the "flag"). It simulates the exact technical hurdles an engineer faces during a real-world penetration test or incident investigation.

- Tabletop: It is a guided discussion meeting where the crisis committee sits down to resolve a hypothetical cyber disaster scenario that evolves in real time.

Simulations that could be implemented:

1. Capture the flag:

Isolated test environments can be built to conduct Capture the Flag exercises, aimed at security team personnel to analyze, find, and resolve vulnerabilities. For example, by capturing network traffic traces.

2. Tabletop:

Specifically aimed at the company's disaster response team to analyze in an isolated environment a real attack in progress that compromises information assets.

Source: <https://www.cloudrangecyber.com/resources/faq/cyber-attack-simulation>

Answer Saved.

Previous

Next



Item 13 of 13

Aside from cyber-attack training, identify and describe two other types of training that can help staff to understand the importance of cyber security.

Data Classification and Privacy Compliance

This training focuses on the legal and ethical obligations of employees and citizens when handling sensitive consumer data. In my experience, I had to align myself with both U.S. and Colombian regulations.

Aside from regular training, employees receive training on the specific laws of each country and of each company involved (clients).

Physical Security and Social Engineering Countermeasures

This training focuses on the physical and social engineering, helping them understand that defences are ineffective if an attacker enters through the weakest link by manipulating human behaviours.

This sort of training combines physical device protection with the recognition of intrusion tactics and social engineering, such as:

- Drop attacks
- Infection via Personal Devices
- Tailgating/Piggybacking
- Clean Desk Violations
- Impersonation Scams

Answer Saved.

[< Previous](#)

[Submit Assessment >](#)